

**ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«САНКТ-ПЕТЕРБУРГСКИЙ НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ
УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ,
МЕХАНИКИ И ОПТИКИ»**

Факультет безопасности информационных технологий

Дисциплина:

«Теория информационной безопасности и методология защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №2

Руководящие документы ФСТЭК

Выполнил:

Студент гр. N3248

Жук Анастасия Валерьевна

Проверил:

Кондратенко Станислав Сергеевич

Санкт-Петербург

2024 г.

Цель: изучить основные руководящие документы ФСТЭК и научиться применять их для практических задач.

Задачи:

1. Ознакомиться с руководящими документами:

- Защита от НСД термины
(<https://fstec.ru/tekhnicheskaya-zashchita-informatsii/dokumenty/114-spetsialnye-normativnye-dokumenty/386-rukovodyashchij-dokument-reshenie-predsdatelya-gostekhkommisii-rossii-ot-30-marta-1992-g3>)

+

Концепция защиты от НСД

- Автоматизированные системы. Защита от НСД
(<https://fstec.ru/tekhnicheskaya-zashchita-informatsii/dokumenty/114-spetsialnye-normativnye-dokumenty/384-rukovodyashchij-dokument-reshenie-predsdatelya-gostekhkommisii-rossii-ot-30-marta-1992-g>)

- №187з

- Средства вычислительной техники. Защита от НСД
(<https://fstec.ru/tekhnicheskaya-zashchita-informatsii/dokumenty/114-spetsialnye-normativnye-dokumenty/385-rukovodyashchij-dokument-reshenie-predsdatelya-gostekhkommisii-rossii-ot-30-marta-1992-g2>)

- СВТ. Межсетевые экраны. Защита от НСД
(<https://fstec.ru/tekhnicheskaya-zashchita-informatsii/dokumenty/114-spetsialnye-normativnye-dokumenty/383-rukovodyashchij-dokument-reshenie-predsdatelya-gostekhkommisii-rossii-ot-25-iyulya-1997-g>)

- <https://habr.com/post/311978/>

- https://www.anti-malware.ru/analytics/Market_Analysis/infosecurity-systems-classification-fsb-fstek

2. Решить представленные кейсы.
3. Сделать вывод о том, в каком порядке необходимо начинать решение различных задач.

Ход работы

Словарь сокращений

РД – руководящие документы

НСД – несанкционированный доступ

АС – автоматизированные системы

СВТ – средства вычислительной техники

МЭ – межсетевой(-ые) экран(-ы)

СЗИ – средства защиты информации

ПДн – персональные данные

ИСПДн – информационная система персональных данных

ИС – информационные системы

ГИС – государственные информационные системы

АСУ – автоматизированные системы управления

ПТИ – программно-техническое исполнение

СОВ – системы обнаружения вторжения

СДЗ – средства доверенной загрузки

ИТ – информационные технологии

ИБ – информационная безопасность

Теория. Средства защиты информации и их классификация

Введем несколько определений для понимания профессиональных терминов.

Опр. *Средства защиты информации (СЗИ)* – это средства, обеспечивающие защиту информации в информационных системах, по сути представляющих собой совокупность хранимой в базах данных информации, информационных технологий, обеспечивающих ее обработку, и технических средств. [1]

Опр. *Несанкционированный доступ (НСД)* – это проникновение в систему злоумышленником посредством преодоления выстроенной системы защиты информации. [1]

ФСТЭК России под системой защиты информации от НСД понимает совокупность мер организационного характера и программно-технических СЗИ от НСД. [1] Функциональность СЗИ от НСД должна предотвращать или существенно затруднять несанкционированное проникновение в обход правил разграничения доступа, реализованных штатными средствами. Эти средства входят в состав средств вычислительной техники и автоматизированных систем в виде совокупности программного и технического обеспечения.

Средства вычислительной техники (СВТ) являются элементами, из которых строятся автоматизированные системы (АС).

Опр. *Автоматизированные системы (АС)* – массивы данных об объектах и явлениях реального мира вместе с программно-аппаратными средствами для их обработки. [3]

Опр. *Средства вычислительной техники (СВТ)* – совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем. [2]

СЗИ регуляторы:

Опр. *Межсетевые экраны* – средства, реализующее контроль за информацией, направленной в АС или исходящей из нее. [1] Межсетевые экраны выполняют фильтрацию информации по заданным критериям.

Опр. Средства обнаружения вторжений (COB) – это средства, автоматизирующие процесс контроля событий в системе (сети) с проведением анализа этих событий с целью поиска признаков инцидента ИБ. [1]

Опр. Антивирусные СЗИ – средства, выявляющие и соответствующим образом реагирующие на средства несанкционированного уничтожения, блокирования, модификации, копирования информации или нейтрализации СЗИ. [1]

В рамках реализации мер по управлению доступом предусмотрено обеспечение так называемой *доверенной загрузки*. Для этого применяются также соответствующие СЗИ. [1]

Меры по защите машинных носителей информации в части обеспечения контроля за их использованием реализуются с помощью *средств контроля съемных носителей*. [1]

Классификация защищенности средств вычислительной техники

Группа:		4	3			2		1
Класс защищенности	- отличительный признак	Верификационная защита	Мандатный механизм			Дискреционная защита		-
	- номер	1	2	3	4	5	6	7
Показатели защищенности:		Перечень показателей	Перечень показателей	Перечень показателей	Перечень показателей	Перечень показателей	Перечень показателей	Перечень показателей

←
НАИВЫСШИЙ КЛАСС
НАИЗЫШИЙ КЛАСС

Рисунок 1 – Классы защищенности средств вычислительной техники

7 класс: должны содержать механизмы защиты от НСД к информации, но итоговая защищенность их ниже защищенности средств 6-го класса. [1]

6 и 5 классы: дискреционное управление доступом – механизм позволяет задавать правила доступа пользователей к различным ресурсам, в которых явно указано, что именно можно делать субъекту: читать содержимое файла, выполнять запуск программы и т. д.

4, 3 и 2 классы: мандатное управление доступом – использование классификационных меток. Они позволяют пользователям и ресурсам назначать

т. н. классификационные уровни, например — категории секретности обрабатываемой информации. Так, создается иерархическая структура, в которой пользователь может получить доступ к ресурсу в том случае, если его уровень в созданной иерархии не ниже уровня иерархии требуемого ресурса. В случае неиерархической структуры в классификационный уровень пользователя включают те классификационные уровни ресурсов, доступ к которым этому пользователю должен быть обеспечен.

При этом в этих средствах вычислительной техники присутствует механизм дискреционного управления доступом: дискреционные правила служат дополнением мандатных.

1 класс: верифицированная защита – должен гарантированно обеспечивать перехват диспетчером доступа всех обращений субъектов доступа к объектам.

Классификация средств защиты автоматизированных систем

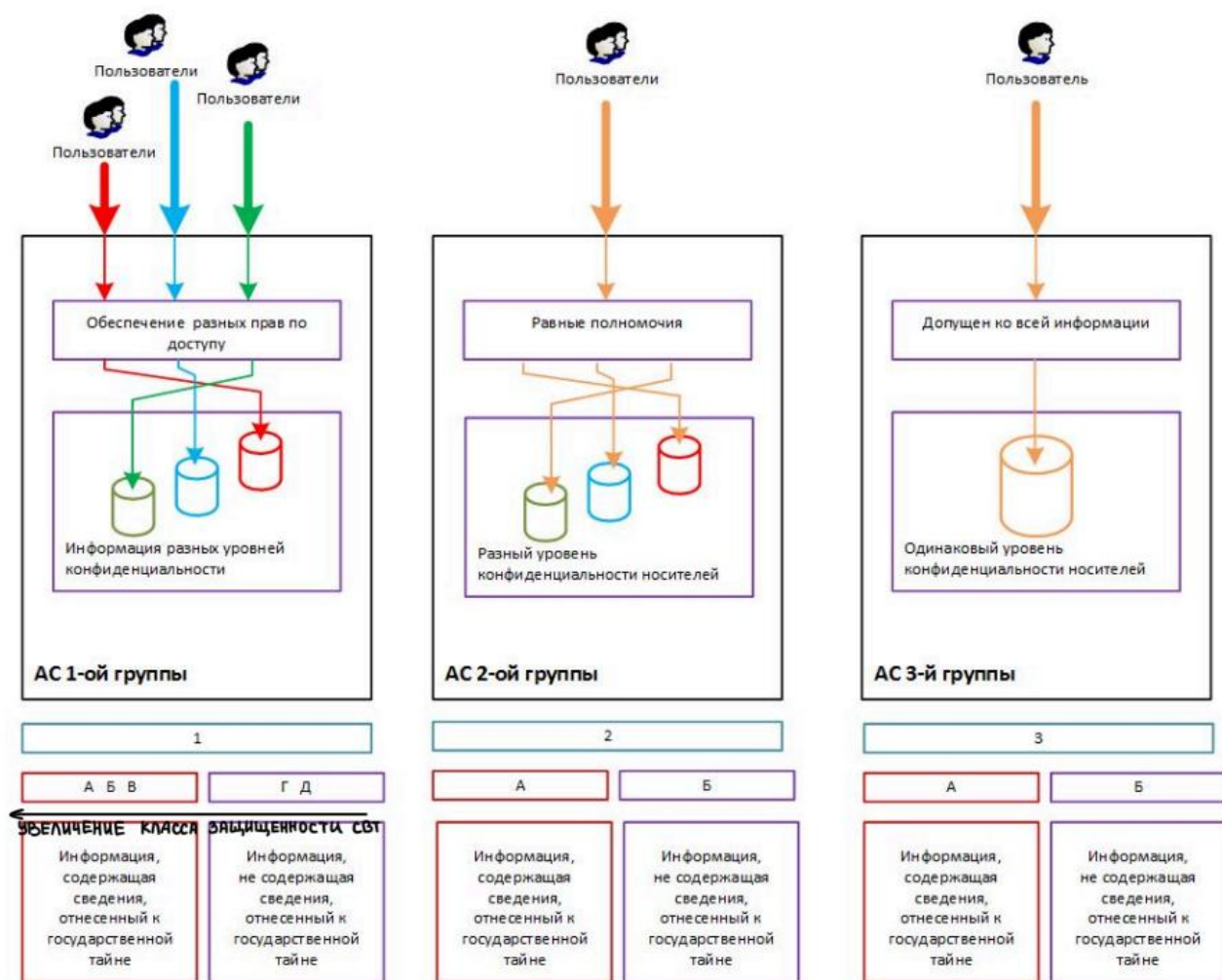


Рисунок 2 – Классы защищенности автоматизированных систем

Классы защищенности межсетевых экранов

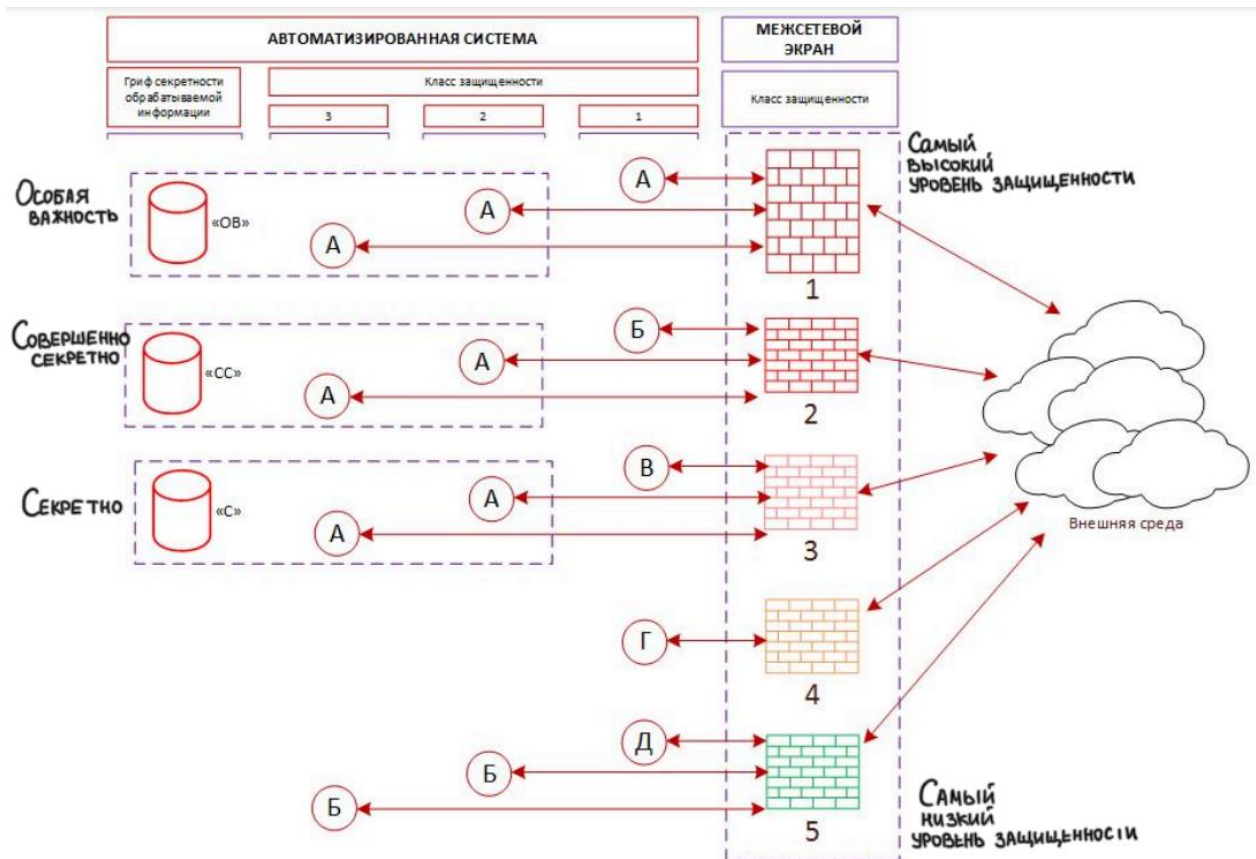


Рисунок 3 – Классы защищенности межсетевых экранов

Классы защиты межсетевых экранов

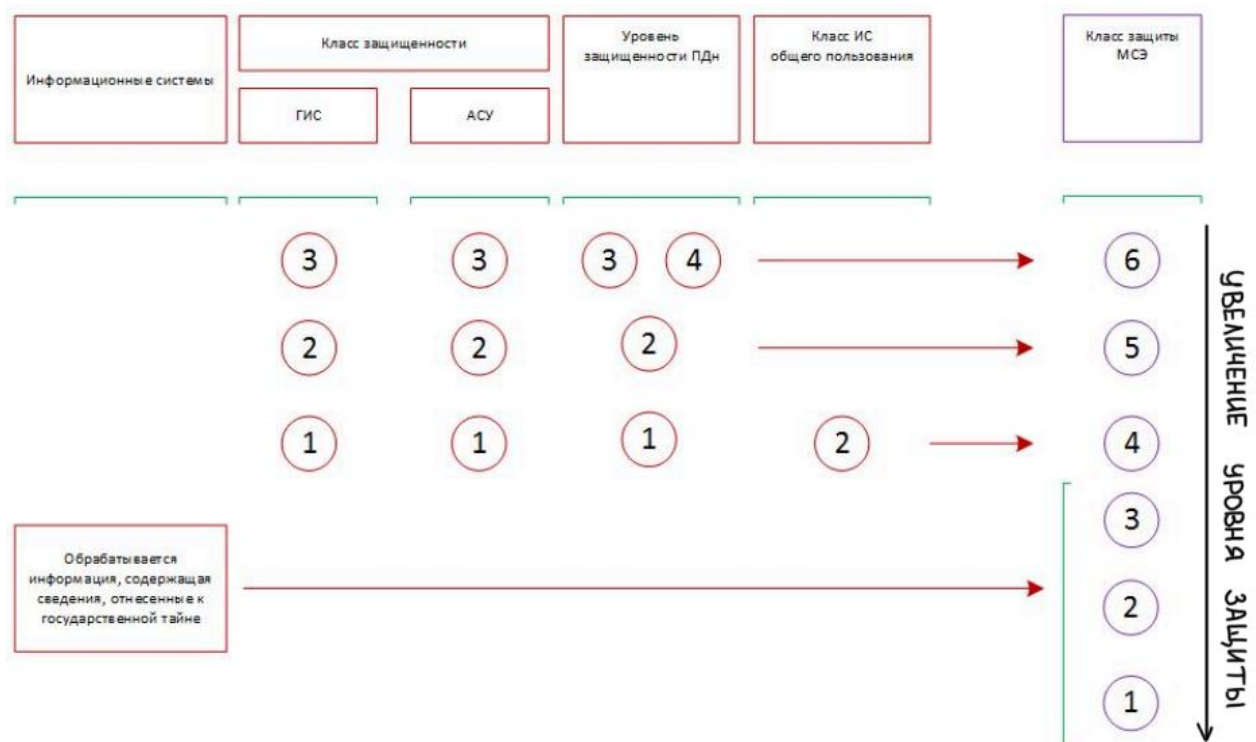


Рисунок 4 – Классификация межсетевых экранов по классам защиты

Типы межсетевых экранов

Регулятор выделяет межсетевые экраны уровня [\[1\]](#):

- сети (тип «А»);
- логических границ сети (тип «Б»);
- узла (тип «В»);
- веб-сервера (тип «Г»);
- промышленной сети (тип «Д»).

Межсетевые экраны типа «А» реализуется только в программно-техническом исполнении. «Б», «Г» и «Д» могут быть как в виде программного продукта, так и в ПТИ. Исключительно в виде программного продукта реализуется межсетевые экраны типа «В».

Таблица 1 – Классы защищенности СВТ и МЭ в зависимости от классификации АС [\[4\]](#)

Доп. параметры		Гриффы				
		Гос. тайна			Конфиденциальная информация	
		ОВ (особой важности)	СС (совершенно секретно)	С (секретно)	...	
Классификация АС	один пользователь	3А			3Б	
	пользователи имеют одинаковые права доступа ко всей информации	2А			2Б	
	не все пользователи имеют право доступа ко всей информации	1А	1Б	1В	1Г	1Д
Класс защищенности СВТ		1,2	3	4	5	6
Класс защищенности МЭ		1	2	3	4	5

В таблице нет только 7 класса защищенности СВТ, но он просто слабее 6, поэтому его не включают в основную часть таблицы.

Кейсы

Исходя из изученной информации, начинать решать различные задачи кейсы лучше с определения АС. Потом, основываясь на том, какая АС используется, можно будет и определиться с МЭ и СВТ.

1. На заводе, производящем автомобильные детали, хотят произвести модернизацию и перейти от бумажного документооборота к электронному. Рассматриваемое предприятие не является государственным, однако в архивах отдела кадров хранятся некоторые сведения, составляющие персональные данные сотрудников. Компьютерами на предприятии могут пользоваться сотрудники, работающие в бухгалтерии и отделе кадров, а также директор предприятия, причем бухгалтера имеют доступ только к “числам”, а кадровики – только к “характеристикам”. Новая система должна обеспечивать защиту от утечек информации о поставщиках, так как в этом заинтересованы заводы-конкуренты, которые не раз пытались произвести кражу такой информации на бумажных носителях, устраивая на завод работать своих сотрудников.

Решение:

АС 1 группы, так как происходит разграничение доступа: бухгалтера имеют доступ только к “числам”, а кадровики – только к “характеристикам”, а директор – ко всем данным. Класс защищенности – 1Г, так как нет информации, относящейся к государственной тайне, но есть ПДн сотрудников, а эту информацию нужно защищать.

Класс защищенности МЭ должен быть 4, так как АС 1Г (см. табл. 1). Класс защиты – 4, так как АС 1 группы. Использовать следует МЭ типа «Б», так как предполагаем, что связь с интернетом происходит с помощью маршрутизатора, но если через кабель, то можно воспользоваться типом «А».

СВТ: сервер, ПК сотрудников. Класс защищенности – 5, так как АС 1г (см. табл. 1).

Также для обеспечения защиты следует применить следующие СЗИ:

- Системы аутентификации и авторизации;
- Шифрование;
- Антивирусное программное обеспечение;
- Физические средства защиты;
- Системы обнаружения вторжения;
- Средства резервного копирования данных.

Ответ:

АС	1Г
СВТ	5
МЭ	4

2. В городском архиве необходимо заменить АС и СВТ в связи с сокращением штата сотрудников до одного человека (содержание архива было полностью перенесено на электронные носители несколько лет назад, поэтому для обеспечения корректной его работы не требуется много сотрудников). Единственным сотрудником архива является его директор, который, также как и руководство города имеет доступ ко всей информации в архиве и даже такой, которая составляет государственную тайну и хранится в архиве под грифом совершенно секретно.

Решение:

АС 2 группы, так как остается всего два пользователя, которые имеют одинаковые права доступа ко всей информации. Так как есть доступ к информации, составляющей государственную тайну, то АС 2А.

Так как гос. тайна хранится под грифом совершенно секретно, то подойдет МЭ с не менее 2 классом защищенности, при этом его класс защиты может быть 1, 2 или 3. Использовать следует МЭ типа «Б», так как предполагаем, что связь с интернетом происходит с помощью маршрутизатора, но если через кабель, то можно воспользоваться типом «А».

СВТ: сервер, ПК директора и руководителя города, системы резервного копирования. Класс защищенности СВТ 3.

Также для обеспечения защиты следует применить следующие СЗИ:

- *Системы аутентификации и авторизации;*
- *Шифрование;*
- *Антивирусное программное обеспечение;*
- *Физические средства защиты;*
- *Системы обнаружения вторжения.*

Ответ:

АС	2А
СВТ	3
МЭ	2

3. ИП, занимающийся производством ручных изделий, имеет собственные секреты производства. Он хочет сохранить всю информацию о производимом товаре и также автоматизировать весь документооборот. Он занимается всем этим один. Несмотря на то, что он один должен иметь доступ ко всей информации о фирме, он переживает, что кто-то все таки может воспользоваться его отсутствием в арендованном кабинете и все узнать.

Решение:

АС 3Б, так как всего один пользователь, и нет никакой информации, содержащей гос. тайну.

МЭ подойдет 5 класса защищенности и 6 классом защиты. Использовать следует МЭ типа «В», так как информация хранится на одном компьютере.

СВТ: сервер, ПК ИП. СВТ будет иметь 5 класс защищенности, так как пользователь переживает за сохранение секретов производства.

Также для обеспечения защиты следует применить следующие СЗИ:

- *Системы аутентификации и авторизации;*
- *Шифрование;*
- *Антивирусное программное обеспечение;*
- *Физические средства защиты;*

- Системы обнаружения вторжения;
- Средства резервного копирования данных.

Ответ:

АС	ЗБ
СВТ	5
МЭ	5

4. В компании, имеющей штат сотрудников более 100 человек, используется единая система для передачи всех данных, связанных с компанией, однако у данной системы нет свободного выхода в сеть интернет. В небольших офисных помещениях сотрудники могут без особого труда получить доступ к компьютерам других сотрудников. Высокопоставленные сотрудники при передаче данных имеют доступ к информации, к которой не все сотрудники имеют право доступа. Конфиденциальная информация в системе не передается.

Решение:

АС 1 группы, так как пользователей много, и не все они имеют право доступа ко всей информации. Так как конфиденциальная информация в системе не поддерживается, то АС 1Д.

МЭ подойдет 5 класса защищенности и 4 классом защиты. Использовать следует МЭ типа «В», так как нет выхода в интернет.

СВТ: сервера, ПК сотрудников. СВТ будет иметь 6 класс защищенности.

Также для обеспечения защиты следует применить следующие СЗИ:

- Системы аутентификации и авторизации;
- Шифрование;
- Антивирусное программное обеспечение;
- Физические средства защиты;
- Системы обнаружения вторжения;
- Средства резервного копирования данных.

Ответ:

АС	1Д
СВТ	6
МЭ	5

5. На предприятии, состоящем из нескольких сотрудников, было решено реализовать “информационную сеть”, позволяющую производить документооборот. При реализации данного проекта было решено, что через “сеть” можно передавать любую информацию любому из пользователей, даже составляющие производственную тайну. Доступ к “сети” можно получить с любого устройства, подключенного к сети интернет, авторизовавшись в специальном приложении.

Решение:

АС 2Б, так как несколько сотрудников имеют одинаковые права доступа ко всей информации.

МЭ подойдет 4 класса защищенности, так как все таки можно передавать информацию, составляющую производственную тайну, и 5 классом защиты. Использовать следует МЭ типа «Г», так как мы пытаемся обезопасить “информационную сеть”.

СВТ: сервер, ПК сотрудников. СВТ будет иметь 5 класс защищенности (в силу производственной тайны, которую нужно сохранить).

Также для обеспечения защиты следует применить следующие СЗИ:

- *Шифрование;*
- *Антивирусное программное обеспечение;*
- *Системы обнаружения вторжения.*

Ответ:

АС	2Б
СВТ	5
МЭ	4

6. На государственном предприятии используется закрытая от внешней среды система передачи данных. Данной системой пользуется

исключительно один рабочий (заведующий архивом). Известно, что в архиве находятся данные с грифами “совершенно секретно” и “секретно”, при этом может осуществляться их дистрибуция. Доступ к данной системе можно осуществить исключительно со специального ПК в архиве при помощи авторизации пользователя.

Решение:

АС 3А, так как всего один рабочий заведует архивом государственного предприятия.

МЭ подойдет 2 класса защищенности, так как в архиве находятся данные с грифами «совершенно секретно», и 6 классом защиты, так как ГИС без гос. тайны. Использовать следует МЭ типа «В», так как сотрудник всего один, и можно установить МЭ только на его компьютер.

СВТ: сервер, ПК заведующего архивом. СВТ будет иметь 3 класс защищенности.

Также для обеспечения защиты следует применить следующие СЗИ:

- *Шифрование;*
- *Антивирусное программное обеспечение;*
- *Системы обнаружения вторжения;*
- *Средства резервного копирования данных.*

Ответ:

АС	3А
СВТ	3
МЭ	2

7. Государственная энергетическая компания обеспечивает электроэнергией страну. Но, похоже, сотрудники компании имеют очень туманное представление об информационной безопасности. В начале текущей недели новый ИБ-специалист обнаружил, что данные этой компании были похищены трояном-стилером. Дело в том, что ИБ-специалист до этого постоянно искал зараженные корпоративные

машины и старался предупредить о компрометации их владельцев. Так он поступил и в этом случае. ИБ-специалист сказал руководству, что машина сотрудника оказалась заражена из-за того, что тот, кто занимался автоматизацией, скачал фейковый установщик IDE. В итоге допустили утечку данных своих клиентов. Любому желающему «видны» личные данные клиентов, внутренние метрики, платежные данные (включая номера карт и CVV) и так далее. Какие требования РД ФСТЭК не соблюдал сотрудник?

Решение:

АС 1Г, так как сотрудников много, не все имеют право доступа ко всей информации, в доступе конфиденциальная информация, но при этом ничего не сказано о гос. тайну.

МЭ подойдет 4 класса защищенности и 4 классом защиты. Использовать следует МЭ типа «В», чтобы избежать подобных ситуаций в будущем.

СВТ: серверы, ПК сотрудников. СВТ будет иметь 5 класс защищенности.

Также для обеспечения защиты следует применить следующие СЗИ:

- *Антивирусное программное обеспечение;*
- *Системы обнаружения вторжения;*
- *Обучение сотрудников базовым знаниям ИБ.*

Ответ:

АС	1Г
СВТ	5
МЭ	4

Нарушения:

- Скачен фейковый установщик IDE → у сотрудников нет базовых знаний ИБ;
- Старый ИБ-специалист искал зараженные корпоративные машины и старался предупредить о компрометации их владельцев → недостаточный уровень обеспечения профилактики от нарушений ИБ.

Требования РД ФСТЭК, которые не соблюдал сотрудник:

1. Приказ ФСТЭК России от 18.01.2013 №21 “Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных”

Этот приказ устанавливает требования к обеспечению безопасности персональных данных при их обработке в информационных системах. Скачивание фейкового установщика IDE и последующее заражение компьютера свидетельствует о несоблюдении мер по защите персональных данных, что является грубым нарушением данного приказа.

2. Приказ ФСТЭК России от 11.02.2013 №17 “Об утверждении требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах”

Данный приказ содержит требования об обработке и защите информации, не являющейся гостайной, в государственных информационных системах. Утечка данных клиентов свидетельствует о том, что компания не обеспечила должный уровень безопасности информации и нарушила установленные требования.

3. Приказ ФСТЭК России от 14 марта 2014 г. №31 “Об утверждении требований к обеспечению защиты информации в автоматизированных системах управления производственными и технологическими процессами на критически важных объектах, потенциально опасных объектах, а также объектах, представляющих повышенную опасность для жизни и здоровья людей и для окружающей природной среды”

Приказ регламентирует работу по защите информации в автоматизированных системах, управляющих опасными производственными процессами. Поскольку компания является частью критической инфраструктуры, она должна следовать этим требованиям.

4. Методика ФСТЭК России от 14.02.2008 “Методика определения актуальных угроз безопасности персональных данных при их обработке в информационных системах персональных данных”

Указанная методика предполагает регулярный анализ и оценку угроз безопасности информации. Неполноценный анализ безопасности данных, непринятие мер по предотвращению заражения компьютера и игнорирование предупреждений ИБ-специалиста указывает на недостаточное внимание к оценке рисков и угроз.

Заключение

Изучив материалы по классификациям защищенности от НСД АС, СВТ и МЭ, можно сделать вывод о порядке решения задач по обеспечению безопасности:

1. Анализа АС, с которой производится работа:
 - Сколько пользователей;
 - Как обеспечиваются права доступа;
 - Содержит ли информация гос. тайну.
2. Определение класса защищенности АС.
3. Определение классов защищенности МЭ и СВТ по классу защищенности АС с акцентом на то, есть ли какие-нибудь дополнительные сведения, которые нужно защитить.

Список используемых источников

1. Anti-Malware, Александр Веретенников. Классификация средств защиты информации от ФСТЭК и ФСБ России: статья. 2018. Режим доступа: https://www.anti-malware.ru/analytics/Market_Analysis/infosecurity-systems-classification-fsb-fstek (дата обращения 16.10.2024).
2. Нетология. Средства вычислительной техники (СВТ): статья. 2024. Режим доступа: <https://netology.ru/glossariy/sredstva-vychislitelnoy-tehniki-svt> (дата обращения 16.10.2024).
3. Информатика. Учебное пособие. Автоматизированные системы: понятие, состав, виды: статья. 2024. Режим доступа: <https://tpt.tom.ru/sved/umk/obscheobraz/uchebnik/ais.htm> (дата обращения 16.10.2024).
4. Хабр. Сводная таблица РД ФСТЭК (до профилей защиты) по порядку и в разрезе грифов: статья. 2016. Режим доступа: <https://habr.com/ru/articles/311978/> (дата обращения 16.10.2024).
5. Завтра облачно, Елена Шпрингер. Что такое межсетевой экран и почему он должен быть сертифицирован ФСТЭК: простое объяснение: статья. 2020. Режим доступа: <https://cloud.vk.com/blog/mezhsetevoj-ekran-pochemu-on-doljen-byt-sertificirovan-fstek>. (дата обращения 16.10.2024).